TP MITM (Activité 1 partie 1-3)

Q1.Pourquoi l'accès aux machines virtuelles par la console ou l'interface graphique n'est pas possible avec le super-administrateur root ?

L'accès root direct est désactivé pour des raisons de sécurité.

Q2. Expliquer à quoi sert la commande sudo et quels avantages a-t-elle sur l'utilisation de la commande su - ?

La commande sudo permet à un utilisateur d'effectuer des commandes root a son nom sans passer par root. L'utilisateur doit faire partie des sudoers.

Q3. Quelles commandes permettent de savoir si le service OpenSSH (serveur) est déjà installé et démarré ?

systemctl status openssh

Q4. Indiquer le répertoire où sont stockées les clés publique et privée créées ainsi que le
positionnement des permissions appliquées sur les fichiers correspondants. Puis indiquer
quel est le fichier de configuration du service SSH.

Stockage des clés :
/home/etusio/.ssh/

Fichier de configuration :
/etc/ssh/ssh_config

Q5. Que signifie cette alerte qui est affichée à l'écran ? Devez-vous continuer l'opération ?
Pourquoi ?

Ce message apparaît quand on essaye de se connecter pour la première fois à une machine en ssh.
L'alerte nous informe que l'authenticité de l'hôte ne peut pas être établie. Le message indique que la clé du serveur n'est pas encore connue. Taper yes pour établir la connexion en ssh.

Q6. Lors d'une prochaine connexion depuis le même client sur ce serveur, ce message apparaîtra-t- il à nouveau ? Pourquoi ?

Lors des prochaines connexions au serveur depuis la même machine le message n'apparaîtra plus. La machine cliente a ajouté l'hôte à la liste des hôtes connus.

Q7. Sur la machine virtuelle cliente, expliquer à quoi sert le fichier /home/etusio/.ssh/known_hosts.

Sur la VM cliente, le fichier /home/etusio/.ssh/known_hosts sert à stocker tous les hosts que la machine connaît pour se connecter en ssh.

Q8. Indiquer quelles sont les informations que peut obtenir un attaquant grâce à ces commandes ?

Avec nmap, un attaquant peut connaître l'OS de la machine, les ports actifs (les services actifs) de la machine (nmap -sV @IP).
Il peut aussi connaître les machines présentes dans le réseau (nmap -sP @IP/mask).

Q9. Expliquer les principes généraux d'une attaque de l'homme du milieu (Man in the Middle).

Une attaque Man In The Middle est lorsqu'un attaquant se place entre les deux machines pour intercepter et relayer les communications entre deux machines, sans qu'elles s'en rendent compte.

Q10.Noter les associations adresse IP / adresse MAC présentes sur les deux machines. Sont-elles cohérentes ?

```
etusio@srvssh:~$ ip neigh
192.168.56.12 dev enp0s3 lladdr 08:00:27:b7:b0:4d STALE
192.168.56.11 dev enp0s3 lladdr 08:00:27:b8:f5:c4 STALE
192.168.56.254 dev enp0s3 lladdr 08:00:27:2d:32:da STALE
```

```
link/ether 08:00:27:f2:64:95 brd ff:ff:ff:ff:ff:ff
inet 192.168.56.10/24 brd 192.168.56.255 scope global enp0s3
```

```
etusio@clissh:~$ ip neigh
192.168.56.10 dev enp0s3 lladdr 08:00:27:f2:64:95 STALE
```

```
link/ether 08:00:27:b8:f5:c4 brd ff:ff:ff:ff:ff:ff
inet 192.168.56.11/24 brd 192.168.56.255 scope global enp0s3
```

Les adresses IP correspondent aux adresses MAC des machines.

Q11.Pourquoi l'activation du routage sur la machine de l'attaquant est indispensable au bon fonctionnement de l'attaque MITM ?

L'activation du routage de la machine attaquante est indispensable pour relayer les paquets entre le client et le serveur.

Q12.Pourquoi cette redirection de ports est indispensable au succès de l'attaque de l'homme du milieu ?

On doit effectuer une redirection de port vers le port 2222 car le serveur ssh utilise déjà le port 22.

Q13.Indiquer en quoi une attaque de type ARP Spoofing peut être utile ici au pirate ?

L'attaque de type ARP Spoofing permet à l'attaquant d'associer l'adresse MAC de sa machine à l'ip de la machine cliente. Ainsi, le pirate peut réceptionner les trames ethernet destiné à la machine cliente.

Q14.Comparer les caches ARP du client et du serveur avec les associations notées précédemment lors de la question 10. Qu'en concluez-vous ?

```
etusio@clissh:~$ ip neigh
192.168.56.12 dev enp0s3 lladdr 08:00:27:b7:b0:4d STALE
192.168.56.10 dev enp0s3 lladdr 08:00:27:b7:b0:4d REACHABLE
```

```
etusio@srvssh:~$ ip neigh
192.168.56.12 dev enp0s3 lladdr 08:00:27:b7:b0:4d STALE
192.168.56.11 dev enp0s3 lladdr 08:00:27:b7:b0:4d REACHABLE
192.168.56.254 dev enp0s3 lladdr 08:00:27:2d:32:da STALE
```

IP de la machine kali linux :

```
link/ether 08:00:27:b7:b0:4d brd ff:ff:ff:ff:ff:ff
inet 192.168.56.12/24 brd 192.168.56.255 scope global noprefixroute eth
```

L'ip de la machine cliente 192.168.56.11 est associée à l'adresse MAC de la machine attaquante.

Q15.À partir de ces différentes observations, expliquez en détails comment fonctionne une attaque ARP Spoofing.

Une attaque ARP Spoofing consiste pour l'attaquant à envoyer de fausses réponses ARP aux machines du réseau (client et serveur), afin de leur faire croire que l'adresse IP de l'autre correspond à sa propre adresse MAC.

Q16.Envoyer une requête ping (icmp-écho) depuis le client vers le serveur (192.168.56.10). Puis vérifier à l'aide d'une capture de trame sur la machine Kali Linux que ces dernières passent effectivement bien par l'attaquant. Quels éléments démontrent que l'attaque se déroule correctement ?

Destination	Protoc	Len	Info
PcsCompu_f2:64:95	ARP	42	192.168.56.11 is at 08:00:27:b7:b0:4d
PcsCompu_b8:f5:c4	ARP	42	192.168.56.10 is at 08:00:27:b7:b0:4d

```
[Duplicate IP address detected for 192.168.56.10 (08:00:27:b7:b0:4d) - also in use by 08:00:27:f2:64:95
[Duplicate IP address detected for 192.168.56.11 (08:00:27:b8:f5:c4) - also in use by 08:00:27:b7:b0:4d
```

L'attaque se déroule correctement, la machine attaquante s'approprie l'adresse IP de la machine cliente, cela explique le double de l'adresse IP cliente.

Q17.Recopier la ligne qui contient le login et le mot de passe capturés dans le fichier /var/log/auth.log.

```
Dec  4 15:27:41 kali sshd_mitm[11230]: INTERCEPTED PASSWORD: hostname: [192.168.56.10]; username: [etusio]; password: [Fghijkl1234*] [preauth]
Dec  4 15:27:41 kali sshd_mitm[11230]: Accepted password for ssh-mitm from 192.168.56.11 port 39332 ssh2
```

Le login et mot de passe ont été enregistrés.

Q18.Que contient le fichier /home/ssh-mitm/shell_session_1.txt présent sur Kali Linux ?
NB : L'accès à ce fichier nécessite l'utilisation de la commande sudo.

```
  GNU nano 4.9.1                                                    /home/ssh-mitm/shell_session_1.txt
Time: 2025-12-04 14:37:39 GMT
Server: 192.168.56.10:22
Client: 192.168.56.11:39334
Username: etusio
Password: Fghijkl1234*
------------------------
Linux srvssh 4.19.0-8-amd64 #1 SMP Debian 4.19.98-1+deb10u1 (2020-04-27) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Dec  4 15:27:41 2025 from 192.168.56.12^M
^[]0;etusio@srvssh: ~^G^[[01;32metusio@srvssh^[[00m:^[[01;34m~^[[00m$ ssuuddoo  aacctt^?^H^[[K^?^H^[[K^?^H^[[K^?^H^[[K  ccaatt  //eettcc//sshhaaddooww^M
[sudo] Mot de passe de etusio : Fghijkl1234*^M
root:!:18350:0:99999:7:::
daemon:*:18350:0:99999:7:::
bin:*:18350:0:99999:7:::
sys:*:18350:0:99999:7:::
sync:*:18350:0:99999:7:::
games:*:18350:0:99999:7:::
man:*:18350:0:99999:7:::
lp:*:18350:0:99999:7:::
mail:*:18350:0:99999:7:::
news:*:18350:0:99999:7:::
uucp:*:18350:0:99999:7:::
proxy:*:18350:0:99999:7:::
www-data:*:18350:0:99999:7:::
backup:*:18350:0:99999:7:::
list:*:18350:0:99999:7:::
irc:*:18350:0:99999:7:::
gnats:*:18350:0:99999:7:::
nobody:*:18350:0:99999:7:::
_apt:*:18350:0:99999:7:::
systemd-timesync:*:18350:0:99999:7:::
systemd-network:*:18350:0:99999:7:::
systemd-resolve:*:18350:0:99999:7:::
messagebus:*:18350:0:99999:7:::
avahi-autoipd:*:18350:0:99999:7:::
sshd:*:18350:0:99999:7:::
systemd-coredump:!!:18350::::::
bind:*:18351:0:99999:7:::
etusio:$6$Yqys3EFqtuzpDS1n$vw7AQUgE0UOvrkY3ORKKYRFoOBFrfn6n3ts8pvvBznkyJcC.zV9G//K9SMj50zh1TPZFXL1A7XBPvJy/gQWg6.:18551:0:99999:7:::
^[]0;etusio@srvssh: ~^G^[[01;32metusio@srvssh^[[00m:^[[01;34m~^[[00m$ ssuuddoo  iipp  ^?^H^[[Kttaabbllleess  --LL^M
Chain INPUT (policy ACCEPT)
```

On obtient le mot de passe du pc serveur, le hash du mot de passe.

```
Chain INPUT (policy ACCEPT)
target     prot opt source               destination

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
^[]0;etusio@srvssh: ~^G^[[01;32metusio@srvssh^[[00m:^[[01;34m~^[[00m$
```

On a aussi les règles de filtrages présentes sur le serveur.
Le fichier contient les commandes tapé en SSH.

Q19.Expliquer pourquoi ce message d'erreur apparaît ?

Ce message apparaît car la machine cliente ne reconnaît pas l'empreinte de la machine serveur pour l'ip 192.168.56.10 . La machine cliente à associer l'empreinte de la machine attaquante pour l'ip 192.168.56.10 . Ce qui explique ce message.

Q20.Proposer une solution afin de pouvoir à nouveau se connecter au service SSH depuis le client.

echo > ~/.ssh/known_hosts
Supprimer le contenu du fichier know_hosts

**Q21.Pourquoi l'algorithme ECDSA a été préféré à l'algorithme RSA lors de la génération de la paire
de clés ?**

L'ECDSA permet d'atteindre le même niveau de sécurité que le RSA avec des clés beaucoup plus petites. Une clé ECDSA de 256 bits est considérée comme équivalente à une clé RSA de 3072 bits.

**Q22.A votre avis, pourquoi la mise en place de cette phrase de chiffrement pour accéder à la clé privée est extrêmement importante ?
La phrase de chiffrement sert de mot de passe pour accéder à la clé privée.**

Q23.Lister le contenu du répertoire $HOME/.ssh/ puis afficher le contenu du fichier id_ecdsa.pub.

```
etusio@clissh:~$ ls $HOME/.ssh/
id_ecdsa  id_ecdsa.pub
```

ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBJBDMyRPWaUtvZKrule8ORuKyK5YjQd4bf1I7hPCdItDcmHmSYnZVDixzRniYbd6MJOXndakzlfoCmePU02aidE= etusio@clissh

```
etusio@clissh:~$ ssh-copy-id -i ~/.ssh/id_ecdsa.pub etusio@srvssh.local.sio.fr
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: "/home/etusio/.ssh/id_ecds
a.pub"
The authenticity of host 'srvssh.local.sio.fr (192.168.56.10)' can't be established.
ECDSA key fingerprint is SHA256:lPIxEKxsYHPP3i7iMiZZXLYUoW9viLwSfF39MNoWlM4.
Are you sure you want to continue connecting (yes/no)? yes
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any
that are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now i
t is to install the new keys
etusio@srvssh.local.sio.fr's password:

Number of key(s) added: 1

Now try logging into the machine, with:   "ssh 'etusio@srvssh.local.sio.fr'"
and check to make sure that only the key(s) you wanted were added.
```

Q24.Sur la machine cliente clissh.local.sio.fr, modifier les droits du fichier ~/.ssh/id_ecdsa (droits initiaux : 600 etusio:etusio) qui contient votre clé privée en 644. Se connecter sur le serveur distant srvssh.local.sio.fr qui contient la clé publique. Que se passe-t-il ? Pourquoi ?

```
etusio@clissh:~$ sudo chown 644 ~/.ssh/id_ecdsa
[sudo] Mot de passe de etusio :
etusio@clissh:~$ ssh etusio@srvssh.local.sio.fr
Load key "/home/etusio/.ssh/id_ecdsa": Permission denied
etusio@srvssh.local.sio.fr: Permission denied (publickey).
```

La connexion en ssh est refusée car la clé privée est lisible par un autre utilisateur que etusio.

Q25.Rétablir les droits de ~/.ssh/id_ecdsa sur le poste client. Maintenant sur le serveur distant, afficher les droits d'accès appliqués au fichier ~/.ssh/authorized_keys.

```
etusio@srvssh:~$ ls -l $HOME/.ssh/authorized_keys
-rw------- 1 etusio etusio 175 déc.   4 16:42 /home/etusio/.ssh/authorized_keys
```

Q26.Puis, modifier les droits de ~/.ssh/authorized_keys en 666. Se déconnecter puis se reconnecter.
Vérifier si un changement est apparu ou non et tenter d'expliquer pourquoi (ne pas oublier de rétablir les droits d'origine ensuite).

```
etusio@srvssh:~$ sudo chown 666 $HOME/.ssh/authorized_keys
```

La connexion échoue

Q27.En analysant la connexion par clés, proposer une hypothèse de fonctionnement de cette nouvelle forme d'authentification. Expliquer ce qui différencie une connexion par mot de passe d'une connexion par clé de chiffrement.

L'authentification par clé fonctionne en utilisant une clé privée sur le client et une clé publique sur le serveur. Le client prouve son identité en signant un message avec sa clé privée, sans jamais envoyer de mot de passe.
La différence est qu'avec un mot de passe, l'utilisateur envoie directement un secret au serveur, alors qu'avec les clés, aucun secret ne circule.

Q28.Suite à la mise en place de cette authentification par clés de chiffrement, tenter à nouveau de simuler une attaque MITM entre le client et le serveur SSH. Quel résultat obtenez-vous ? Pourquoi ?

L'attaque MITM échoue, car le serveur n'accepte plus les mots de passe et utilise uniquement l'authentification par clé. L'attaquant ne peut pas récupérer la clé privée du client, donc il ne peut pas s'authentifier à sa place.
Même s'il intercepte la connexion, il ne peut pas se faire passer pour le client.
Le MITM devient inutile avec les clés.

Q29.Expliquer l'intérêt de cette démarche.

Publier les empreintes SSH dans le DNS permet au client de vérifier automatiquement que la clé du serveur est la bonne avant la première connexion.
Cela évite à l'utilisateur de vérifier l'empreinte manuellement.
On réduit ainsi les risques de MITM lors de la première connexion.

Q31.Expliquer dans une définition succincte ce qu'est l'état de l'art dans le domaine de la cybersécurité.

L'état de l'art correspond aux méthodes et algorithmes considérés comme sûrs et recommandés à un instant donné.
Il repose sur les recherches récentes et les standards de sécurité actuels.
On l'utilise pour garantir un niveau de protection moderne et efficace.
Il est mis à jour régulièrement.

Q32.Définir ce qu'est le principe de Kerckhoffs.

Le principe de Kerckhoffs dit que la sécurité d'un système ne doit jamais dépendre du secret de l'algorithme.
Seule la clé doit rester secrète.
L'algorithme, lui, peut être public sans réduire la sécurité.

Q33.Selon ce principe, pourquoi est-il pertinent de choisir des algorithmes cryptographiques connus et respectant l'état de l'art ?

Choisir des algorithmes publics et reconnus permet d'utiliser des méthodes qui ont été testées et validées par des experts.
Ils sont plus fiables que des algorithmes non vérifiés.
On évite ainsi d'utiliser un chiffrement vulnérable.